Contoh kasus hak akses: Rina

Isi tabel user, role_permission, dan access untuk kasus Rina mengubah jadwal unit

Catatan. Semua data di dokumen ini adalah **contoh rekaan** untuk ilustrasi, bukan isi database sebenarnya. Di staging ada user *rinawjy* (Rina Wijaya, peran Admin Warehouse), tetapi di contoh ini Rina dianggap memegang peran baru bernama Koordinator.

Ide dasarnya

Mirip kartu akses di gedung kantor: ada **siapa orangnya**, **apa jabatannya**, dan **pintu mana yang boleh dibuka**.

Konsep	Analogi	Di database
User	Seorang karyawan dengan kartu masuknya	`hr.users`
Role (peran)	Jabatan atau seragam. Satu jabatan dipegang banyak orang, aturannya ditulis sekali.	kolom `role` di `hr.users`, dan tabel `role_permission`
Permission (izin)	Satu pintu atau aksi: boleh melihat jadwal, boleh mengubah jadwal	`access.permission`
User permission	Pengecualian untuk satu orang: izin tambahan (allow) atau pencabutan (deny)	`access.user_permission`
access	Hanya nama schema (folder tabel) untuk semua tabel hak akses	`access.*`

1. Tabel hr.users (sudah ada)

Hanya kolom role yang menghubungkan user ke aturan.

user_id	username	employee_name	role	is_active
`u-001`	veronica	Veronica Yudhishiana	Superadmin	true
`u-002`	**rina**	**Rina Wijaya**	**Koordinator**	true
`u-003`	budi	Budi Santoso	Finance	true

2. Tabel access.permission (daftar izin yang sah)

Mencegah salah ketik: izin yang tidak ada di daftar ini tidak bisa diberikan.

key	feature	action	description
`schedule:view`	schedule	view	Melihat jadwal unit
`schedule:edit`	schedule	edit	Mengubah jadwal unit
`schedule:export`	schedule	export	Mengunduh laporan jadwal (CSV)
`access:manage`	access	manage	Mengelola hak akses

3. Tabel access.role_permission (peran dan izinnya)

Satu baris adalah satu pasangan peran dan izin. Kolom scope kosong berarti berlaku untuk semua data (disiapkan untuk aturan berbasis data nanti). Tanda * berarti semua izin.

role	permission_key	scope
Superadmin	*	(kosong)
Koordinator	`schedule:view`	(kosong)
Koordinator	`schedule:edit`	(kosong)
Finance	`schedule:view`	(kosong)
Finance	`schedule:export`	(kosong)

4. Tabel access.user_permission (pengecualian per user)

Awalnya kosong. Dua contoh pengecualian untuk Rina (hijau = allow, merah = deny):

user_id	permission_key	effect	granted_by	note
`u-002` (Rina)	`schedule:export`	allow	`u-001`	Menyusun laporan bulanan
`u-002` (Rina)	`schedule:edit`	deny	`u-001`	Cuti, sementara tidak boleh ubah

Cara izin akhir dihitung

Mulai dari izin peran, tambahkan **allow** khusus user, lalu kurangi **deny** khusus user. **Deny selalu menang.** Izin yang tidak tercatat berarti ditolak.

Kondisi	Izin akhir Rina
Hanya peran Koordinator	`schedule:view`, `schedule:edit`
Ditambah allow export	`schedule:view`, `schedule:edit`, `schedule:export`
Ditambah juga deny edit	`schedule:view`, `schedule:export` (**edit dicabut, deny menang**)

Selama baris deny itu ada, server menolak Rina saat menekan Ubah jadwal. Begitu baris itu dihapus, Rina boleh lagi, tanpa mengubah perannya atau peran orang lain.

5. Tabel access.audit_log (setelah Rina mengubah jadwal)

Catatan siapa mengubah apa dan kapan. Satu baris contoh ditampilkan vertikal agar mudah dibaca. Perubahan izin juga dicatat di tabel yang sama.

Kolom	Isi	Artinya
`id`	1	Nomor urut catatan
`at`	2026-11-09 09:14	Kapan perubahan terjadi
`user_id`	`u-002` (Rina)	Siapa yang mengubah
`permission_key`	`schedule:edit`	Izin yang dipakai
`entity`	schedule	Jenis data yang diubah
`entity_id`	K-22	Data yang mana (unit K-22)
`before`	`{"standby": false}`	Isi sebelum diubah
`after`	`{"standby": true}`	Isi sesudah diubah

Perbandingan dengan Finance (Budi)

Budi memegang peran Finance, jadi izinnya `schedule:view` dan `schedule:export`. Dia bisa melihat jadwal dan mengunduh laporan, tetapi tidak bisa mengubah jadwal karena `schedule:edit` tidak ada di perannya.

Alur saat Rina menekan Ubah jadwal

Langkah	Yang terjadi
1	Rina login. Server tahu dia user *rina* dengan peran Koordinator.
2	Rina menekan Ubah jadwal. Web memanggil API.
3	Server menentukan izin yang dibutuhkan endpoint itu: `schedule:edit`.
4	Server menghitung izin Rina: izin peran, plus allow khusus, dikurangi deny khusus.
5	Kalau `schedule:edit` ada di hasilnya, perubahan dilakukan. Kalau tidak, server menjawab 403 dan tidak ada yang berubah.
6	Perubahan dicatat di `access.audit_log`.

Pengecekan terjadi di server. Tombol yang disembunyikan di web hanya kenyamanan, sedangkan yang melindungi data adalah pengecekan di endpoint.